第三课 身份认证

认证协议

认证目的：确认通信双方的真实身份，防止身份伪造。

分类：

- 实体认证（**身份**认证）：确认对方真实身份
  - 单向认证：一方认证另一方
  - 双向认证：彼此认证
- 数据源认证（**消息**认证）：确认消息**完整性**、消息**发送者身份**、消息的**新鲜性**

目的：

- 实体认证： 防止冒充身份
- 数据源认证：防止篡改、伪造、重放

👉 通常，在认证过程中，双方除了确认身份以外， 还会共**享一个会话密钥**，以保护后续的通信。

所以很多认证协议实际上完成：① 证明身份 ② 建立会话密钥

三种身份认证方式

认证方式	核心思想	举例
Know sth	证明你知道某个**秘密**	口令、PIN、密钥、暗号
Have sth	证明你拥有某个**物品**	身份证、IC卡、U盾、令牌
Be sth	证明你具有某种**生物特征**	指纹、人脸、虹膜、DNA

（一）Know sth

口令

最常用的认证机制，但安全性较差，易受到泄露、猜测、窃听、社会工程学（欺骗用户主动泄露密码）等形式的攻击

👉 弱口令：容易猜测

短口令，常见单词，生日、电话号码……，系统预设口令

提高口令安全性：

- 口令空间：长度足够，包含多种字符类型，避免易猜测的数字和字母组合
- 口令时间：具有一定生存期，不应使用一定时间内的历史口令，**降低长期泄露风险**
- 口令保护：用户登录不同系统应使用不同口令，系统设定口令登录失败次数限制（暴力猜测破解）

基于口令的认证机制

用户通过证明自己知道正确的口令（Password），来证明自己的身份。

与基于口令的加密（PBE）的区别：

基于口令的认证	基于口令的加密（PBE）
证明身份	加密数据
利用口令进行身份认证	利用口令推导加密密钥
登录邮箱、登录网银	压缩包加密、文件加密

口令存储

直接明文存储口令， 一旦得到存储口令的数据库，就可得到全体人员的口令 → 风险很大！！！

解决方法：

- 利用 Hash 函数存储口令 — Needham 口令认证协议，**解决存储安全**
- 使用一次性口令机制 — Lamport（S/Key）已在第二课中介绍，**解决传输安全和重放攻击**

(1) Needham

通过保存口令的hash值，替代直接保存口令，解决数据库被偷后直接暴露明文口令

为防止简单口令的字典攻击/暴力破解：加 salt/多次hash

缺点：**不能防范在线窃听口令、离线字典攻击**

> **Note**
>
> **salt — 防止数据库泄露**
>
> 给每个用户随机生成一串字符串（Salt），再与密码组合后进行 Hash。
>
> 服务器会将Salt一起保存，但salt不是秘密，**可以公开保存**
>
> 防止：
>
> - 彩虹表攻击

- 发现相同密码
- 不能完全防止暴力破解，但可以**增加破解成本**

（2）安全传输 — 利用 SSL 建立安全信道

Web场景下的处理方式，防止窃听

先用 HTTPS/SSL协议 建立安全信道，再把用户名和口令发给服务器认证，目的是**保护传输过程，避免口令在网络中被明文窃听**。

（3）EKE协议

加密的密钥交换协议，在不安全信道上，用一个“低熵口令（弱密码）”安全地协商出会话密钥，同时防止被动和主动攻击。

👉 可以抵抗在线口令窃听、离线字典攻击

流程：利用事先共享的弱密码来加密对称加密的密钥

（二）Have sth

系统不需要知道你是谁，拥有这张卡的人，就是合法用户。

👉 身份证、护照、学生证、IC 卡、门禁卡、USB Key、银行 U 盾、手机动态令牌

- 存储卡：只有存储器在磁卡上保存用户信息；与PIN配合使用（know sth），防止丢失
- 智能卡：由一个或多个集成电路芯片组成，包含CPU和存储器，具有数据存储能力和逻辑处理功能

（三）be sth

- 生物特征

  指纹、掌纹、虹膜、视网膜、手形、面部特征、声音特征
- 动态特征

  签名特征（笔画习惯）、键盘特征（打字节奏）

优点：不会忘记，也不需要携带物品

缺点采集设备、误识率、隐私风险和不可更换性

双因子/多因素认证

至少组合两个不同类别的认证因素

- 密码（know）+ 短信验证码（have）
- 银行卡（have）+ PIN（Know）
- 门禁卡（have）+ 指纹（Be）

SSL协议（TLS）

Secure Sockets Layer 安全套接层协议，用于**保护网络通信安全**。

建立在**可靠的传输层协议**之上，例如 TCP；高层应用协议如 HTTP、FTP、Telnet 可以**透明地建立在 SSL 之上**。

使用混合加密：使用公钥密码体制完成身份认证和密钥协商，数据传输阶段使用对称密钥进行加密。

1、目的：在客户端和服务器之间建立一条**安全的加密通信信道**，使双方能够安全地交换数据。

2、安全服务：

- 认证：利用数字证书和可信第三方认证机构，识别通信双方身份
- 机密性：传输数据经过加密处理，防止窃取、篡改和冒充
- 完整性：利用加密算法和 Hash 函数保证传输数据完整

3、两层结构

（1）SSL 握手协议

用来建立连接、完成认证、协商算法和密钥。HTTP三次握手之后，应用数据传输前。

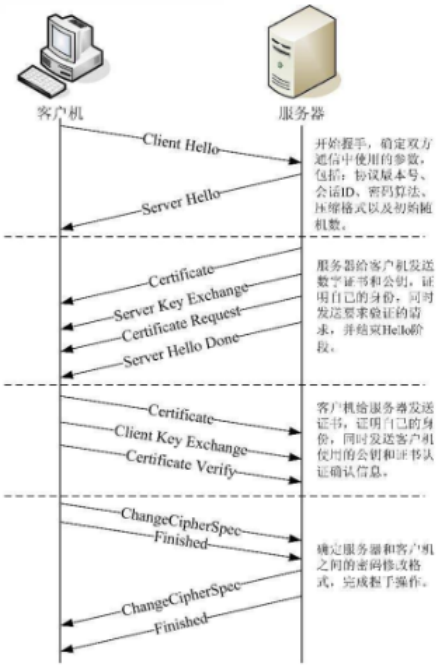


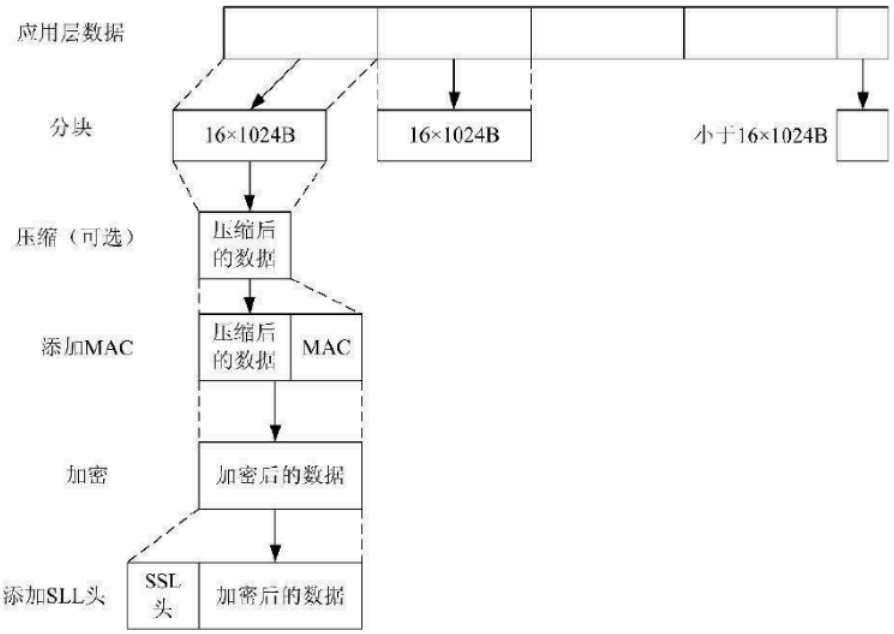
图4-11 SSL握手协议的操作过程

- hello：协商协议版本、加密算法、会话 ID、压缩方法和**随机数**。
- 身份认证阶段：Sever发送数字证书和公钥（公钥在数字证书里），**证明自己的身份（服务器认证）**，同时要求对方发送证明；Client收到后发送证书和公钥，证明自己的身份。
- 完成握手过程：确定密码修改格式，完成握手操作

> **Note**
>
> 随机数：保证每次链接都是新的 Session Key
>
> Cetificate Verify（**证书验证**）：用私钥签名对证书信息，以证明证书确实是自己的。
>
> ChangeCipherSpec：从这一刻开始，我们双方都改用刚刚协商好的会话密钥和加密算法来通信。
>
> Finished：必须在 ChangeCipherSpec 之后，验证整个握手过程没有被篡改。

（2）SSL记录协议

负责实际承载高层应用数据，建立在可靠的传输层协议之上，为高层协议提供数据封装、压缩、加密等基本功能的支持。



- 数据分块：将应用层数据分解为16 x 1024B 或更小
- 数据压缩（可选）：无损
- 计算并添加MAC：用 Hash 函数对压缩后的数据计算 MAC。
- 加密：用对称密钥 AES 对压缩数据和 MAC
- 添加SSL记录头：形成完整SSL记录

👉 握手协议谈规则，记录协议按规则包装数据

对认证协议的典型攻击

中间人攻击

目标：缺少认证的通信协议

方法：攻击者插在双方之间，伪装成对方通信

👉 对密钥交换和身份做认证

旧消息重放

方法：重新发送以前捕获的协议消息

👉 保证新鲜性（消息在有效期内）

保证新鲜性的技术

- 时间戳机制

优点：直接利用系统时间，不用额外交互，通信效率高

缺点：**严重依赖时钟同步**

- 挑战-应答机制（利用随机数）

  优点：不需要时钟同步

  缺点：增加通信开销

交错攻击

❗ 针对挑战-应答机制

方法：攻击者**同时拦截、参与或发起多个并行的协议会话（Session）**，将一个会话中的（数据包中的）**消息**（或消息的一部分），提取出来并**“穿插、拼接”**到另一个并行的会话中，以此来绕过身份认证或伪造密钥。

👉 会话ID、绑定身份标识

平行会话攻击

攻击者利用了系统允许多个连接同时存在的特性，**同时（并发地）**开启并维持了至少两个协议会话（Session）。

❗ **平行会话攻击通常是实施交错攻击的具体场景或载体**。